

Federated Authentication Discussion

Conversation summary from this session

Social IDP (Google/GitHub/LinkedIn)

An Identity Provider (IdP) authenticates users. With social login, users sign in using existing accounts such as Google, GitHub, or LinkedIn. AWS Cognito acts as a broker, redirects users to the provider, validates returned tokens, maps the identity into a Cognito User Pool, and issues Cognito JWTs.

Typical JWT fields:

- identities[].providerName identifies the source provider (Google, GitHub, etc.)
- cognito:username is typically prefixed with the provider, e.g. Google_123456

OAuth 2.0

OAuth focuses on authorization and provides access tokens and refresh tokens.

OIDC (OpenID Connect)

OIDC extends OAuth 2.0 and adds authentication through an ID Token (JWT) that describes who the user is.

Cognizant SSO / Enterprise Federation

Instead of social providers, authentication is delegated to an enterprise identity source such as Azure AD (Microsoft Entra ID) or an internal corporate IdP. Cognito federates with the enterprise provider and then issues Cognito tokens to the application.

Flow: Employee -> Application -> Cognito -> Azure AD/Internal IdP -> Cognito -> Application.

Why use Cognito as a broker?

A single integration supports Google, GitHub, LinkedIn, Azure AD, and other providers while maintaining a consistent JWT format and centralized user management.

Quick comparison

Social Login: Personal accounts, external users, OAuth/OIDC.

Enterprise SSO: Corporate accounts, employees, OIDC or SAML.